

- Filename: comptia-pentest-plus-pt0-002-3-20-1-ics-scada-and-iiot-vulnerabilities.md
- Show Name: Pentest+ (PT0-002)
- Topic Name: Attacks and Exploits
- Episode Name: ICS, SCADA, and IIoT vulnerabilities

ICS, SCADA, and IIoT Vulnerabilities

Objectives:

- List and describe common ICS, SCADA, and IIoT vulnerabilities
-
- What is OT, ICS, SCADA, IIoT?
 - OT Operational Technology
 - Encompassing term for ICS, SCADA, and IIoT
 - ICS = Industrial Control Systems
 - General term for SCADA and Distributed Control Systems(DCS)
 - SCADA = Supervisory Control and Data Acquisition
 - Control System for industrial processes
 - Multiple remote sites with local control systems and equipment
 - Communication systems to connect the whole thing
 - IIoT
 - The convergence of OT and IT
 - Using traditional IT infrastructure to manage OT devices
 - ICS / SCADA / IIoT Security Challenges
 - Plain Text Passwords/Protocols
 - Complexity
 - Proprietary tech
 - Legacy Tech
 - Lack of security professionals
 - Converging with IT brings in IT Security issues
 - OT Vulnerabilities
 - Internet-connected OT systems
 - OT System connected to system that is connected to Internet
 - Missing or Non-existent updates
 - Weak passwords and/or no authentication
 - Weak firewall rules (ingress/egress)
 - Non-existent network segmentation
 - Weak or non-existent encryption
 - IIoT Vulns
 - Ripple20 (<https://www.jsoc-tech.com/disclosures/ripple20/>)
 - 19 vulnerabilities in the Treck TCP/IP stack
 - 4 vulns give RCE rated 9+ CVSS scores
 - OT Threats

- **Malware**

- Introduced through
 - Removable Media
 - External hardware
 - via Internet
 - IT connected systems
 - Web / Database
 - Compromised Cloud
 - Infected end-user devices

- DoS/DDoS

- Sensitive data exposure

- **HMI-based Attacks**

- Buffer Overflows
- Authentication/Authorization
 - Creds in Clear-text
 - Hard-coded creds
 - Sensitive info transmitted in the clear

- Human Error

- **Side-Channel attacks**

- Monitoring physical aspects of the OT
 - Timing Analysis
 - Observe the time it takes to complete password auth process
 - Deduce password or crypto-key
 - Power Analysis
 - Attacker using a oscilloscope observes power consumption between clock cycles

- **RF Connected controller attacks** (attacks against RF communications)

- Replay attacks
 - Capture and replay legit command traffic
- Command Injection
 - Create and inject malicious traffic
- Malicious RF Controller Re-pairing attack
 - "Evil" Controller
- Malicious Reprogramming attack
 - Evil firmware

- Tools

- Shodan
- SearchDiggity
- s7scan
- plcscan
- smartrf packet sniffer (<https://www.ti.com/tool/download/PACKET-SNIFFER-2>)
- ISF (ICS Exploitation Framework)